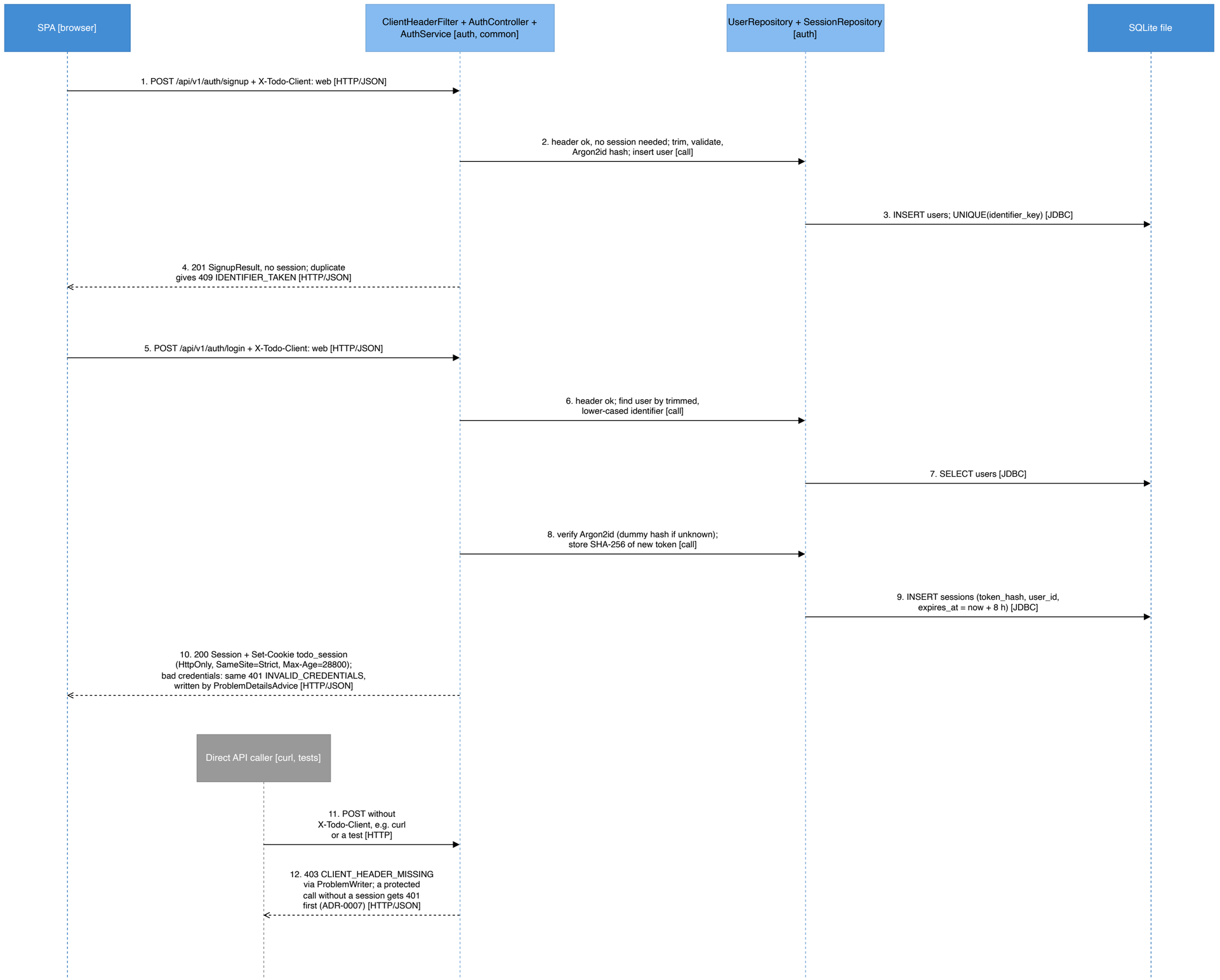
To-do list · Sequence: sign-up, login, session cookie and cross-site header defence
CHG-0001 · frozen spec (supersede-2, approved 2026-11-07) · drawn 2026-11-08
Traces: REQ-AUTH-001, REQ-AUTH-002, REQ-AUTH-003, NFR-004; sdd §2, §4, §5, §6; ADR-0004, 0005, 0007, 0008, 0011, 0015, 0016, 0018; identity-api-v1.yaml signUp, logIn



Cross-origin web page: no CORS is configured, so the browser's preflight fails and no request is sent (ADR-0007). The SPA client wrapper always adds X-Todo-Client on unsafe methods (sdd §2), so the SPA never reaches step 12.

Legend
Boxes at the top are participants (dark blue: container or datastore, light blue: components, grey: a caller outside the app); vertical dashed line: lifeline.
Solid arrow: request or call, numbered in order; dashed arrow: response. Labels end with the protocol or mechanism. Yellow note: remark.